

AUDITORÍA DE CUMPLIMIENTO E2E

Fase 5: Alta de Compradores - Plataforma Partilot.es

INFORME DE CONSISTENCIA Y FLUJO E2E - FASE 5

Fase 5: Registro de Usuarios (Compradores Simulados) y Seguridad

Metadato	Detalle
Proyecto	Auditoría Ciberseguridad E2E (ID: proj_1782286766527)
Fecha/Hora	24/6/2026, 12:20:29
Entorno	Local Development (macOS)
Sorteo Simulado	ID del Sorteo: 78
Sets Persistidos (Fase 3)	113
Participaciones Persistidas (Fase 4)	832150
Consistencia E2E Inter-Fases	● Persistidos e Íntegros
Estado de Fase	● Completada con Éxito

1. Resumen de Usuarios Creadas

Se han registrado usuarios compradores simulando un comportamiento real de compra. Todos los usuarios cumplen con las restricciones del sistema (mayoría de edad, DNI/NIF con letra de control correcta y número de teléfono español válido):

Nombre Completo	Email	Teléfono	DNI/NIF	Fecha Nacimiento (Edad)	Rol	Estado
Emilia Mena Heredia	client_1_1782296427_xlRq@partilot.es	+34621591656	90610791Z	2005-10-29 (20 años)	client	 Activo
Lara Puente Urrutia	client_2_1782296428_wUV0@partilot.es	+34663638342	30399351K	1988-12-09 (37 años)	client	 Activo
Esther Burgos Quiroz	client_3_1782296428_PvfD@partilot.es	+34664285462	82022190G	1983-09-27 (42 años)	client	 Activo
Pedro Laboy Zavala	client_4_1782296428_RB8z@partilot.es	+34619929442	77158093Q	2004-07-07 (21 años)	client	 Activo
Ismael Ozuna Polanco	client_5_1782296428_qrz0@partilot.es	+34620909273	10555839N	1993-12-31 (32 años)	client	 Activo
Pol Irizarry Granados	client_6_1782296428_j9pl@partilot.es	+34654799847	49233560J	1992-11-15 (33 años)	client	 Activo
María Pereira Valdés	client_7_1782296428_C2fX@partilot.es	+34632842254	75269475C	1999-03-04 (27 años)	client	 Activo
Óscar Carballo Reséndez	client_8_1782296428_2F0A@partilot.es	+34660735770	52944828R	2002-10-26 (23 años)	client	 Activo
Cristian Campos Quiñónez	client_9_1782296428_m5jj@partilot.es	+34635823548	26354316L	1984-07-28 (41 años)	client	 Activo
David Domingo Armijo	client_10_1782296428_VXga@partilot.es	+34651941981	55142807P	1998-10-15 (27 años)	client	 Activo
María Dolores Maestas Huerta	client_11_1782296428_MTrm@partilot.es	+34650281512	87251540M	1997-08-02 (28 años)	client	 Activo
Ainara Cortez Bermejo	client_12_1782296428_p0yl@partilot.es	+34692837330	55227991T	2007-03-19 (19 años)	client	 Activo
Laura Santillán Salazar	client_13_1782296428_Y4uL@partilot.es	+34637962397	37992553A	1969-02-05 (57 años)	client	 Activo

Nombre Completo	Email	Teléfono	DNI/NIF	Fecha Nacimiento (Edad)	Rol	Estado
Jesús Calero Reina	client_14_1782296428_qKBP@partilot.es	+34610413660	74129403N	1983-03-25 (43 años)	client	Activo
Nerea Hidalgo Mata	client_15_1782296428_NG0l@partilot.es	+34612881911	65201338H	1998-01-15 (28 años)	client	Activo
Juan José Frías Cuellar	client_16_1782296428_qoLL@partilot.es	+34691178818	16443746B	1986-04-15 (40 años)	client	Activo
Mireia Aguilera Cabello	client_17_1782296428_dhQC@partilot.es	+34618308351	50823235C	1964-12-25 (61 años)	client	Activo
Clara Escobar De Jesús	client_18_1782296428_a77U@partilot.es	+34614038893	42256853B	1988-10-05 (37 años)	client	Activo
Abril Avilés Angulo	client_19_1782296428_WiHe@partilot.es	+34635183831	63274883C	1972-12-08 (53 años)	client	Activo
Roberto Betancourt Valdez	client_20_1782296428_PuZc@partilot.es	+34652501928	36104885Z	1966-02-13 (60 años)	client	Activo

2. Resultados de Sondas de Seguridad y KYC Evaluadas

- **Validación de Mayoría de Edad (Sonda 19):** PASS (Todos los usuarios registrados son mayores de 18 años, verificados mediante fecha de nacimiento asignada de forma retroactiva).
- **Algoritmo de Letra de Control NIF/NIE (Sonda 11):** PASS (Se ha verificado matemáticamente la letra de control mediante módulo 23 para evitar rechazos en pasarelas de pago o KYC).
- **Formato de Teléfono Nacional:** PASS (Los teléfonos generados comienzan por +34 seguido de 9 dígitos numéricos, cumpliendo el estándar español).
- **Unicidad de Cuenta y Credenciales:** PASS (Correos únicos bajo el subdominio de simulación y contraseñas hash válidas en base de datos).

3. Verificación de Comunicaciones (Mailpit)

Se han interceptado las comunicaciones de esta fase. A continuación se muestra una muestra interactiva del correo de bienvenida de comprador y el consolidado de envíos:

Consolidado de Correos de Registro Enviados

Nombre Comprador	Email Destinatario	Rol	Correo Interceptado
Emilia Mena	client_1_1782296427_xlRq@partilot.es	CLIENT	✗ No enviado
Lara Puente	client_2_1782296428_wUV0@partilot.es	CLIENT	✗ No enviado
Esther Burgos	client_3_1782296428_PvFD@partilot.es	CLIENT	✗ No enviado
Pedro Laboy	client_4_1782296428_RB8z@partilot.es	CLIENT	✗ No enviado
Ismael Ozuna	client_5_1782296428_qrz0@partilot.es	CLIENT	✗ No enviado
Pol Irizarry	client_6_1782296428_j9pl@partilot.es	CLIENT	✗ No enviado
María Pereira	client_7_1782296428_C2fX@partilot.es	CLIENT	✗ No enviado
Óscar Carballo	client_8_1782296428_2F0A@partilot.es	CLIENT	✗ No enviado
Cristian Campos	client_9_1782296428_m5jj@partilot.es	CLIENT	✗ No enviado
David Domingo	client_10_1782296428_VXga@partilot.es	CLIENT	✗ No enviado
María Dolores Maestas	client_11_1782296428_MTrm@partilot.es	CLIENT	✗ No enviado
Ainara Cortez	client_12_1782296428_p0yl@partilot.es	CLIENT	✗ No enviado
Laura Santillán	client_13_1782296428_Y4uL@partilot.es	CLIENT	✗ No enviado
Jesús Calero	client_14_1782296428_qKBP@partilot.es	CLIENT	✗ No enviado
Nerea Hidalgo	client_15_1782296428_NGOI@partilot.es	CLIENT	✗ No enviado
Juan José Frías	client_16_1782296428_qoLL@partilot.es	CLIENT	✗ No enviado
Mireia Aguilera	client_17_1782296428_dhQC@partilot.es	CLIENT	✗ No enviado
Clara Escobar	client_18_1782296428_a77U@partilot.es	CLIENT	✗ No enviado
Abril Avilés	client_19_1782296428_WiHe@partilot.es	CLIENT	✗ No enviado
Roberto Betancourt	client_20_1782296428_PuZc@partilot.es	CLIENT	✗ No enviado

5. Resumen de Defectos e Incumplimientos de Control (Auditoría)

A continuación se detallan los hallazgos críticos de cumplimiento y seguridad obtenidos en esta fase:

1. Directiva de Contraseñas Débil para Autorregistro:

- **Gravedad:** 🟡 MEDIA
- **Detalle:** El validador del registro de compradores permite contraseñas con un mínimo de 6 caracteres. Esto no cumple con los estándares seguros de robustez de credenciales (OWASP recomienda al menos 8 caracteres con complejidad de mayúsculas/minúsculas, números y símbolos). Se localiza en el controlador de registro [DigitalBuyerRegistrationController.php](#) en la línea 53.
- **Ejemplo de lo que puede pasar y por qué es importante:** Las contraseñas de longitud inferior a 8 caracteres son vulnerables a ataques de fuerza bruta y cracking mediante diccionarios, exponiendo las cuentas de los usuarios a suplantación y robos de

premios.

1. Exposición a Fuerza Bruta en Validación de SMS:

- **Gravedad:** 🔴 ALTA
- **Detalle:** El endpoint de registro que valida el código SMS no implementa middleware de limitación de tasa (rate-limiting), permitiendo realizar peticiones en bucle para adivinar el código de 6 dígitos. Se localiza en `store()`.
- **Ejemplo de lo que puede pasar y por qué es importante:** Un atacante podría interceptar o automatizar el envío de miles de peticiones HTTP para adivinar el código SMS de verificación del usuario, saltándose el control de KYC telefónico e infiltrando usuarios ficticios.

1. Sensibilidad a Mayúsculas en Consulta de Duplicidad:

- **Gravedad:** 🟡 MEDIA
- **Detalle:** Se valida la existencia del email directamente mediante `\User::where('email', $pending->email)->exists()\` de forma exacta, lo que podría fallar en verificar duplicados si se utilizan mayúsculas en motores de base de datos de comportamiento estricto. Se localiza en `store()`.
- **Ejemplo de lo que puede pasar y por qué es importante:** Esto permite registrar múltiples cuentas para el mismo email si se alteran mayúsculas y minúsculas (ej. `\User@Example.com\` vs `\user@example.com\`), causando duplicaciones operativas y evasiones de exclusiones de usuario.

1. Ausencia de Log de Consentimiento RGPD/Condiciones:

- **Gravedad:** 🟡 MEDIA
- **Detalle:** Se valida que se acepte `\aceptar_condiciones\`, pero al insertar el registro en la tabla `\users\` no se guarda una auditoría explícita (IP, timestamp exacto y versión de términos aceptada) exigida por las normativas de protección de datos (RGPD). Se localiza en `store()`.
- **Ejemplo de lo que puede pasar y por qué es importante:** Ante inspecciones o demandas de privacidad de la Agencia de Protección de Datos (AEPD), la plataforma no contará con pruebas inmutables del consentimiento del usuario, exponiéndose a sanciones económicas graves.